

Re-examine Cache-control Directives (Systemic)

Assessment Identifier: **WS-DYN-12** | Assessment Type: **Dynamic** | Date: **September 08, 2026**

Severity: INFORMATIONAL	CVSS: 0.0	CWE: CWE-525
OWASP: A05:2021 - Security Misconfiguration	WASC ID: 13	Confidence: Low
Target / Component: Authenticated Dashboard Endpoint	Affected URL: https://www.worldmonitor.app/dashboard	Parameter: cache-control

1. Description

The cache-control header has not been set properly or is missing, allowing the browser and intermediate proxy servers to cache content. While caching is intended for static assets like CSS, JavaScript, or image files, pages containing dynamic user data or authenticated content should be explicitly instructed not to cache to prevent sensitive data exposure.

2. Steps to Reproduce

1. Send an HTTP GET request to https://www.worldmonitor.app/dashboard.
2. Inspect the HTTP response headers returned by the server.
3. Locate the Cache-Control header and verify its directives (e.g., public, max-age=0, must-revalidate).

3. Controlled Proof of Concept

HTTP Response Headers:
 cache-control: public, max-age=0, must-revalidate

Bash Verification:
 curl -I -s https://www.worldmonitor.app/dashboard | grep -i "cache-control"

4. Business & Security Impact

Allowing dynamic or user-specific pages (like /dashboard) to be marked as public or cached locally can expose personal user data. On shared computers, non-authenticated users could potentially navigate back using the browser history or retrieve cached sensitive pages directly from the browser/proxy storage.

5. Remediation Recommendations

Primary Fix: Use no-cache, no-store directives on authenticated routes; use immutable caching only for static assets.

1. For dynamic, authenticated, or sensitive endpoints, update the HTTP response headers to instruct browsers and intermediate caches not to store sensitive pages:
 Cache-Control: no-cache, no-store, must-revalidate
 Pragma: no-cache
 Expires: 0
2. For purely static, public assets (e.g., public CSS/JS/images), consider using caching directives with immutability:
 Cache-Control: public, max-age=31536000, immutable

6. Evidence & Validation

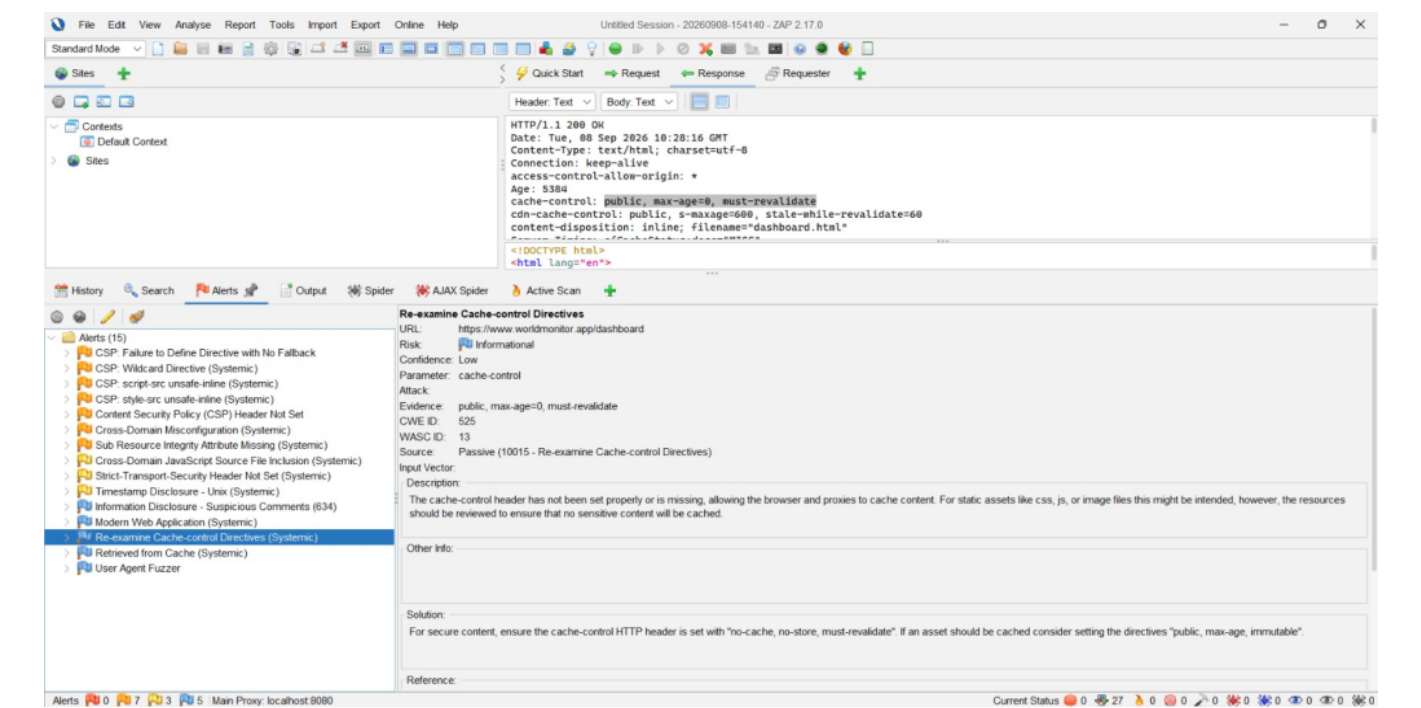


Figure 1: Matched Proof-of-Concept Screenshot for Vulnerability #12 (12/poc-1.png)

Authorization & Safety Compliance: This security assessment was conducted strictly under authorized parameters in accordance with ethical hacking standards. All validations and safe proof-of-concept tests were non-destructive. No persistent modifications or sensitive data exfiltration occurred.